OWASP Top 10 Vulnerabilities – Final Report

1. Introduction

Project Objective:
The objective of this penetration test was to identify and exploit security vulnerabilities in the OWASP Juice Shop web application using the OWASP Top 10 framework. The goal was to evaluate the application's security posture and provide recommendations to mitigate identified risks.

---

2. Methodology

The assessment was conducted using a **black-box testing approach**, simulating an external attacker with no prior access.

Approach:

- Reconnaissance using Burp Suite
- Interception & manipulation of HTTP requests
- Manual payload injection
- Validation using repeatable exploitation

---

3. Tools Used

- VMware Workstation
- Kali Linux
- Docker
- Burp Suite Community Edition
- Firefox Browser

---

4. Findings Summary (Executive Table)

ID	Vulnerability	OWASP Category	Risk	Status
01	SQL Injection Login Bypass	Injection	🔴 High	Exploited

ID	Vulnerability	OWASP Category	Risk	Status
02	Cross-Site Scripting (XSS)	Injection	🔴 High	Exploited
03	Sensitive Data Exposure (/ftp)	Data Exposure	🟠 Medium	Exploited
04	Broken Authentication	Authentication	🟠 Medium	Exploited
05	Security Misconfiguration	Misconfiguration	🟡 Low	Exploited
06	Broken Access Control	Access Control	🔴 High	Exploited

🔹 5. Detailed Findings & Proof of Concept

---

01 - Authentication Bypass via SQL Injection

Description:
The login form is vulnerable to SQL Injection due to lack of input validation.

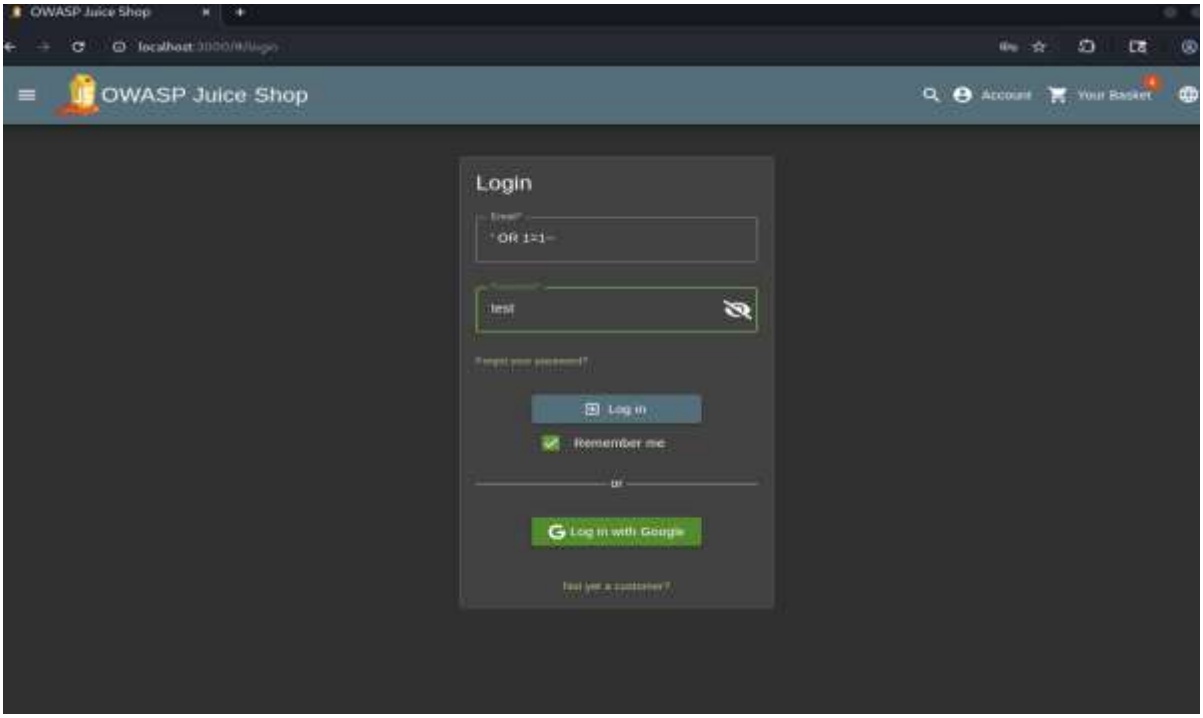
Impact:
Full administrative access without credentials.

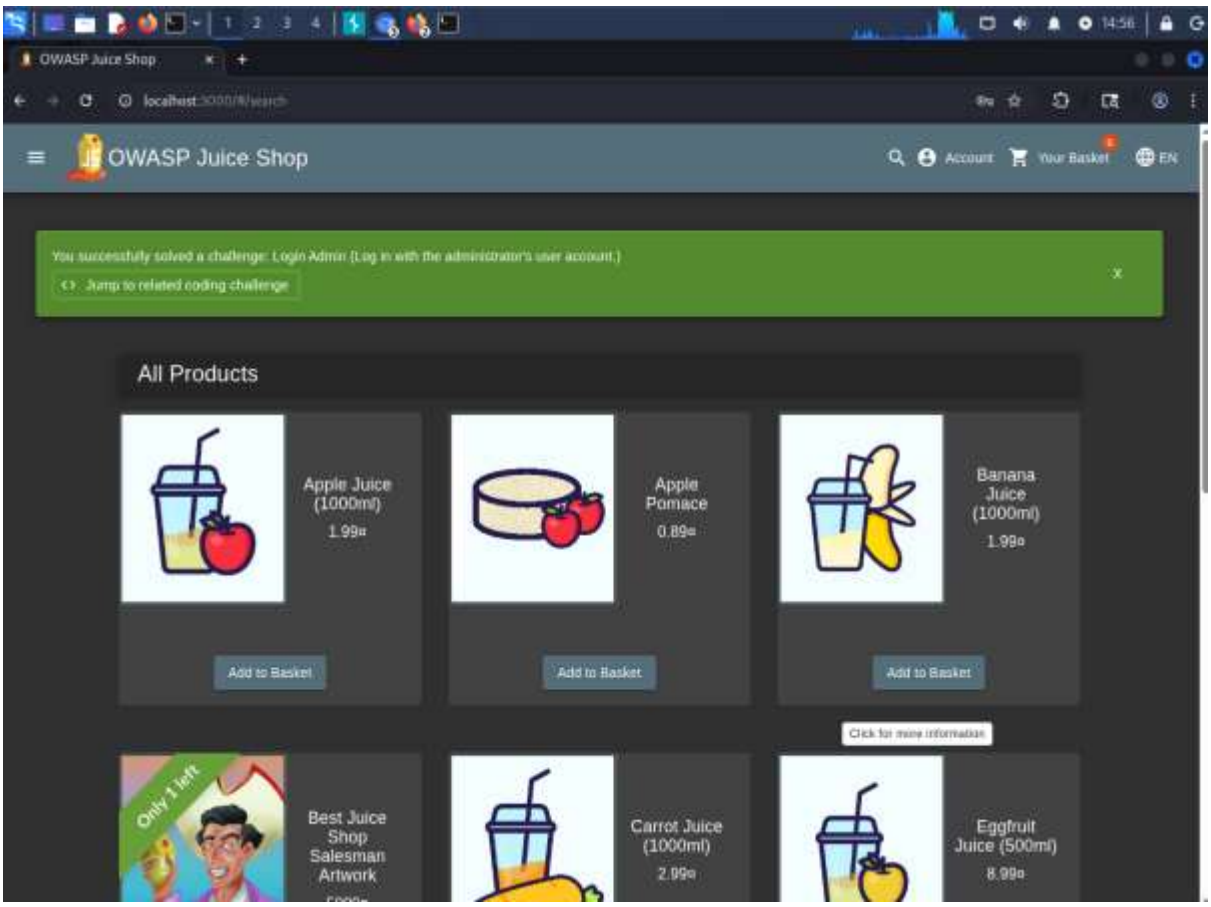
Steps to Reproduce:

1. Go to login page
2. Enter ' OR 1=1-- in email
3. Enter any password
4. Click login

Result:
Successfully logged in as admin.

Screenshots:


OWASP Juice Shop
Account
Your Basket
Login
' OR 1=1--
test
Log in
Remember me
or
Log in with Google


OWASP Juice Shop
Account
Your Basket
EN
You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)
Jump to related coding challenge
All Products
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Banana Juice (1000ml)
1.99¤
Add to Basket
Only 1 left
Best Juice Shop Salesman Artwork
Carrot Juice (1000ml)
2.99¤
Click for more information
Eggfruit Juice (500ml)
8.99¤

02 - Cross-Site Scripting (XSS)

Description:
User input is not sanitized, allowing execution of JavaScript.

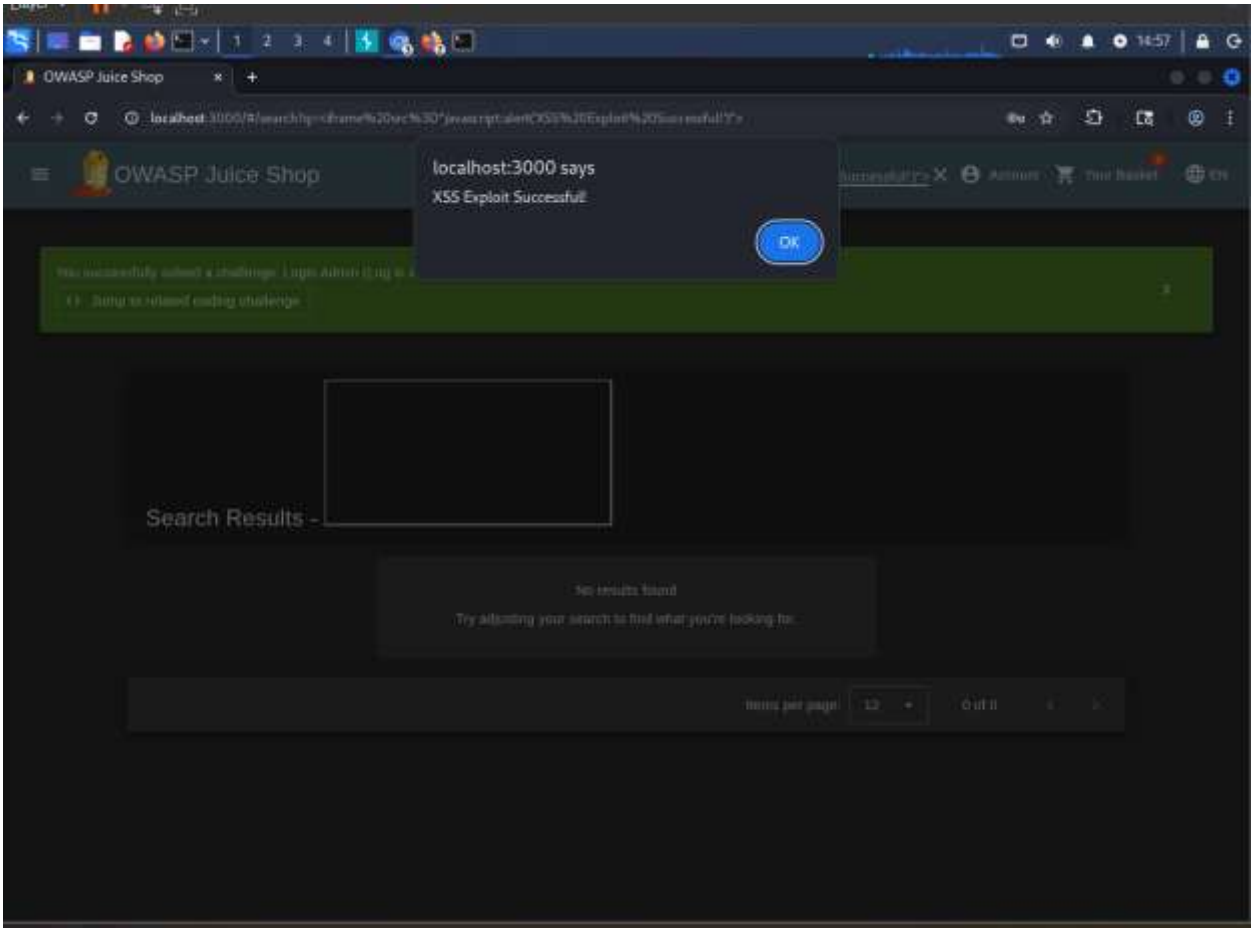
Impact:
Session hijacking and client-side attacks.

Steps to Reproduce:

1. Enter payload in search:
   <iframe src="javascript:alert('XSS Exploit Successful!')">
2. Submit request

Result:
Alert popup executed.

Screenshots:



03 - Sensitive Data Exposure (/ftp)

Description:
Unprotected directory exposes sensitive files.

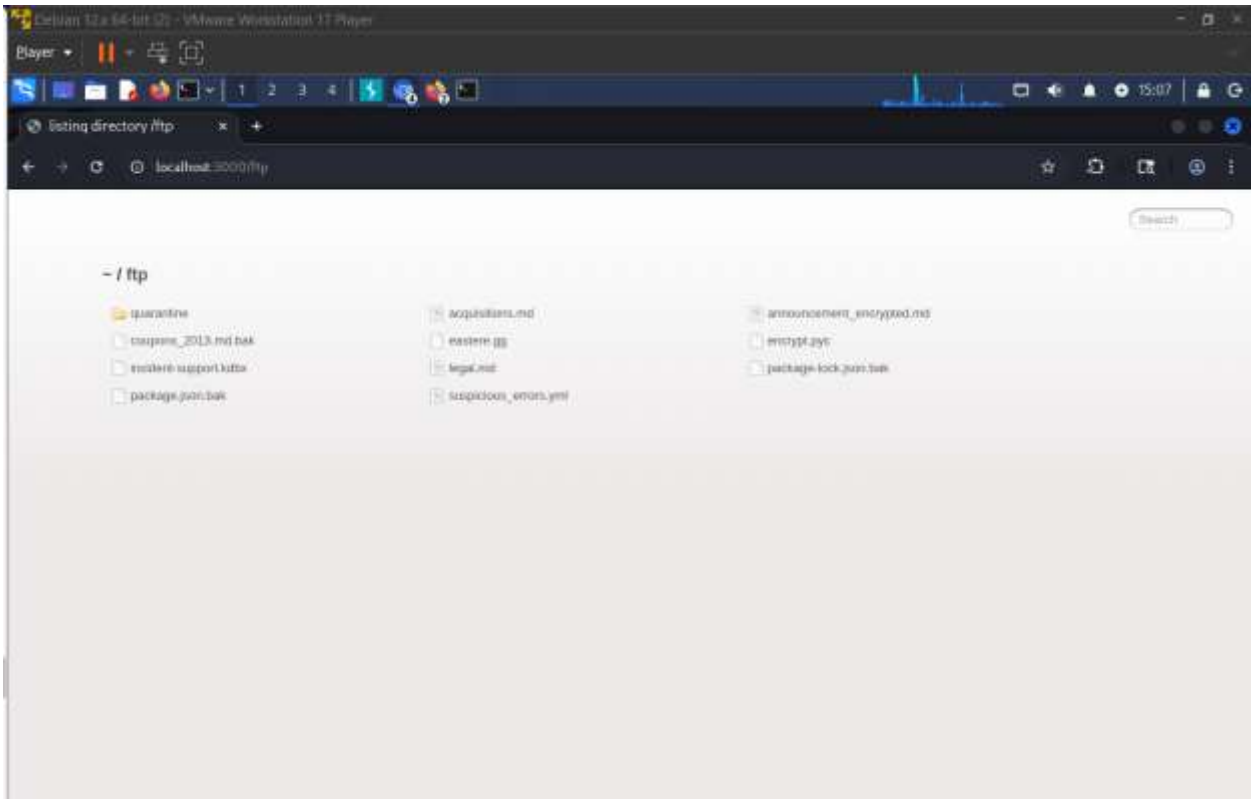
Impact:
Data leakage and potential credential exposure.

Steps to Reproduce:

1. Visit: http://localhost:3000/ftp
2. Access available files

Result:
Sensitive files accessible without authentication.

Screenshots:



---

04 - Broken Authentication

Description:
No rate limiting on login attempts.

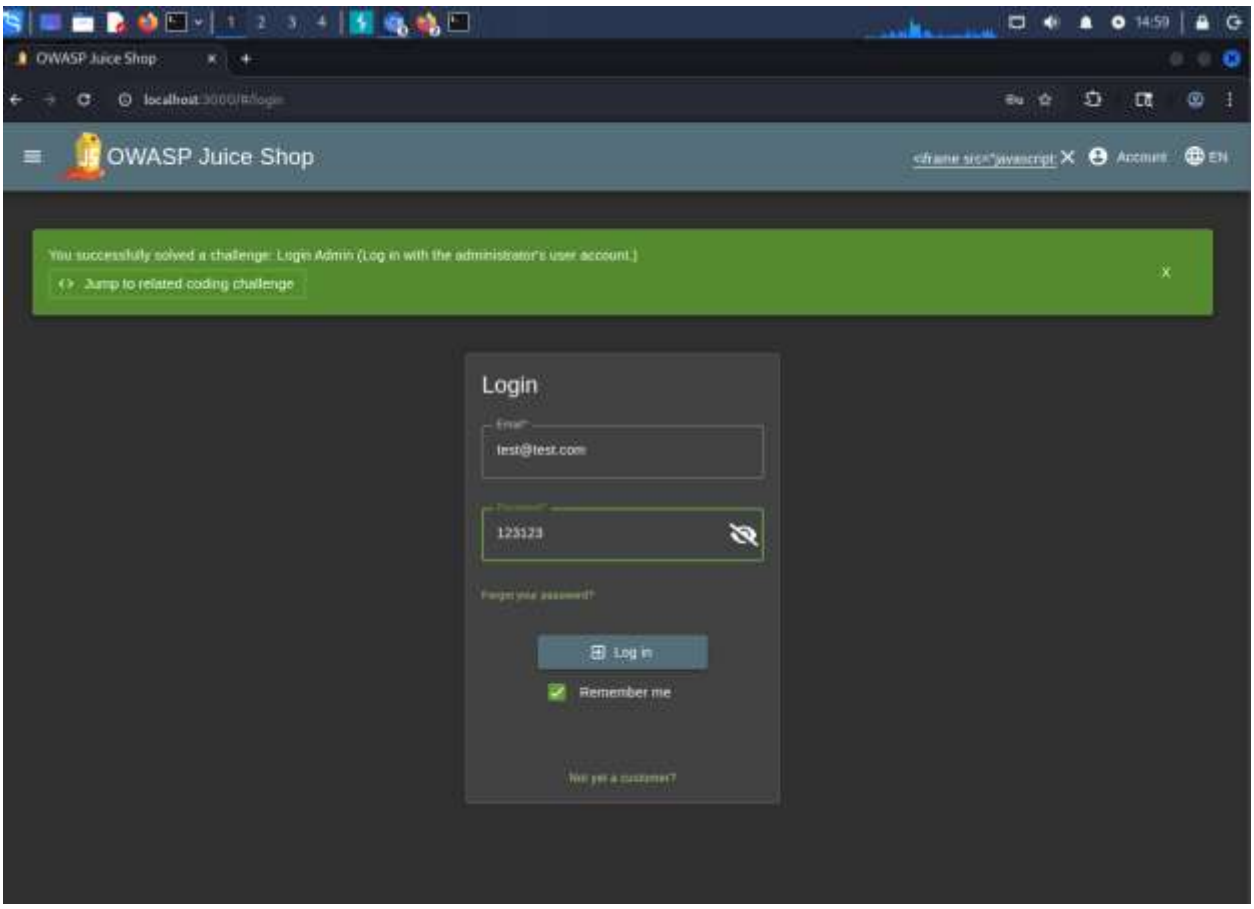
Impact:
Brute-force attacks possible.

Steps to Reproduce:

1. Attempt multiple login tries
2. Observe no blocking

Result:
Unlimited login attempts allowed.

Screenshots:



---

05 - Security Misconfiguration

Description:
Application exposes internal information via HTTP responses.

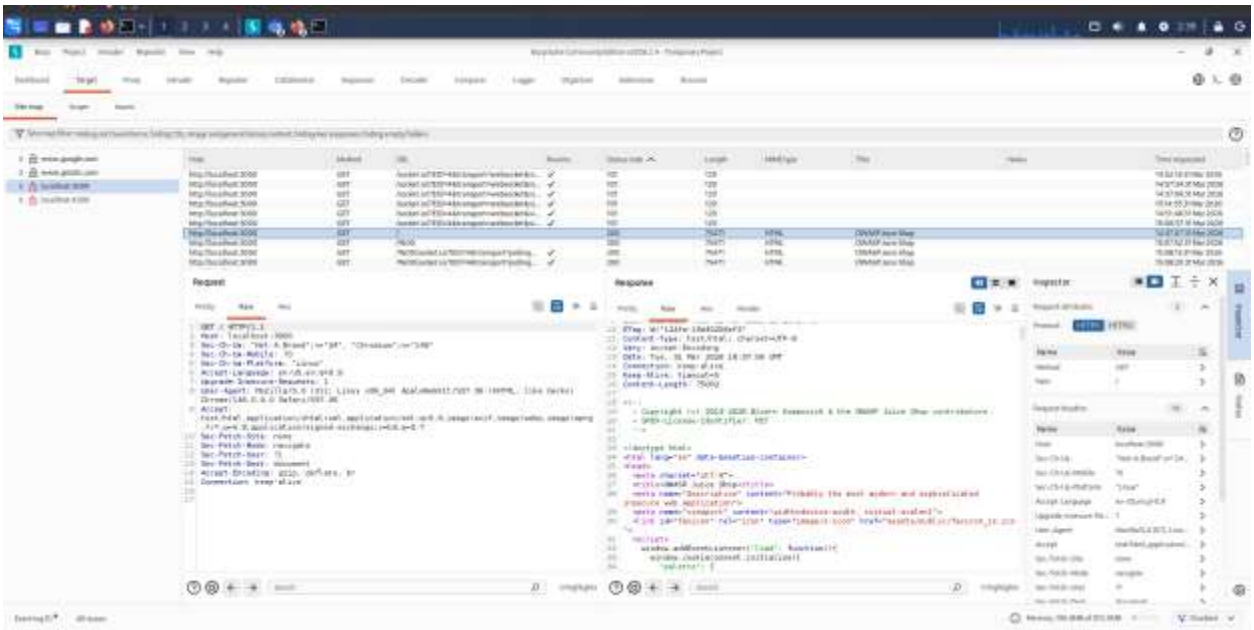
Impact:
Helps attackers understand system structure.

Steps to Reproduce:

1. Intercept request in Burp Suite
2. Analyze response

Result:
Sensitive headers and debug info visible.

Screenshots:



---

06 - Broken Access Control

Description:
Improper access restrictions allow unauthorized admin access.

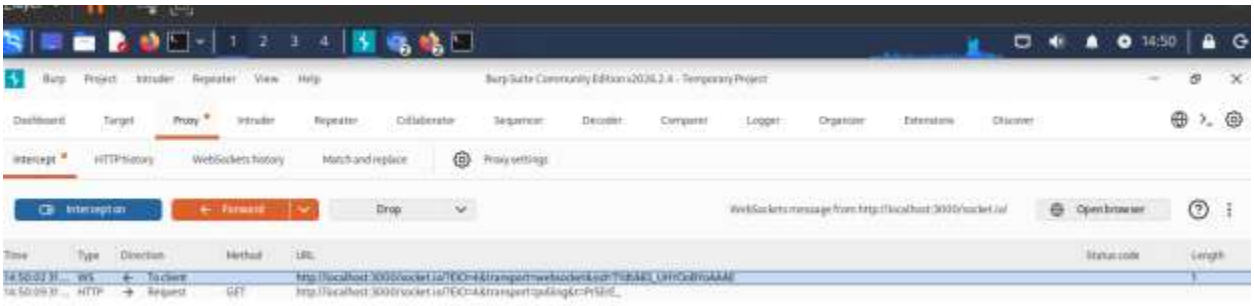
Impact:
Privilege escalation.

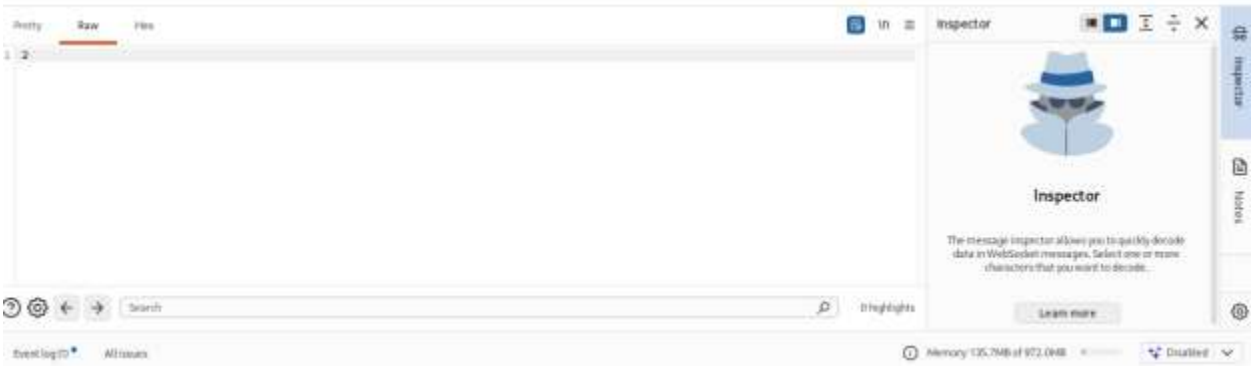
Steps to Reproduce:

1. Intercept request in Burp
2. Modify header:
   X-User-Email: ' OR 1=1--
3. Forward request

Result:
Access to admin data granted.

Screenshots:





---

6. Remediation Recommendations

Vulnerability	Recommendation
SQL Injection	Use prepared statements & input validation
XSS	Sanitize input & implement output encoding
Data Exposure	Restrict directory access & authentication
Broken Auth	Implement rate limiting & CAPTCHA
Misconfiguration	Disable verbose errors
Access Control	Enforce role-based access control

---

7. Conclusion

The penetration testing assessment successfully identified multiple vulnerabilities mapped to the OWASP Top 10 categories, demonstrating significant security gaps in the application. Exploitation of issues such as SQL Injection, XSS, and Broken Access Control highlights weaknesses in input validation, authentication mechanisms, and authorization controls. These vulnerabilities pose serious risks, including unauthorized access and data exposure. Implementing proper security measures and best practices is essential to strengthen the application's overall security. Timely remediation will help prevent potential real-world attacks and improve resilience against future threats.